

Tài liệu: How to Use MITRE ATT&CK in a Security Operations Center

Phần 1: Giới thiệu và Tổng quan về MITRE ATT&CK

1.1. Giới thiệu về MITRE ATT&CK

Khung công tác MITRE ATT&CK là một cơ sở dữ liệu kiến thức **có sẵn toàn cầu** về các chiến thuật và kỹ thuật của kẻ thù, dựa trên **những quan sát từ thực tế**. Nó phục vụ như một nguồn tài nguyên cơ bản để hiểu và lập bản đồ hành vi của kẻ tấn công, cung cấp một khung toàn diện để phân tích các mối đe dọa và xác định các giai đoạn khác nhau của các cuộc tấn công[1][3][5].

1.2. Các thành phần chính của Khung MITRE ATT&CK

- **Tactics:** Những mục tiêu cấp cao trong một vector tấn công, như **Initial Access**, **Execution**, và **Persistence**[3].
- **Techniques:** Những phương pháp cụ thể được sử dụng để đạt được những mục tiêu này, như **Spearphishing** hoặc **Lateral Movement**[3].
- **Sub-techniques:** Các phương pháp chi tiết hơn trong một kỹ thuật, cung cấp cái nhìn sâu sắc về hành vi của kẻ tấn công[3].

1.3. Tầm quan trọng của MITRE ATT&CK trong các Trung tâm Vận hành Bảo mật (SOCs)

MITRE ATT&CK rất quan trọng trong các SOC với một số lý do như sau: - **Threat Intelligence:** Nó cung cấp một phương pháp có cấu trúc để phân tích và hiểu hành vi của các mối đe dọa, nâng cao độ chính xác của thông tin tình báo về mối đe dọa[5]. - **Correlation:** Bằng cách lập bản đồ các sự kiện với các chiến thuật và kỹ thuật của MITRE ATT&CK, các SOC có thể tương quan dữ liệu bảo mật một cách hiệu quả hơn, xác định các mối đe dọa và lỗ hổng tiềm năng[1][3]. - **Incident Response:** Nó giúp phát triển các chiến lược phản ứng sự cố bằng cách cung cấp sự hiểu biết rõ ràng về hành vi và chiến thuật của kẻ tấn công.

1.4. Các phát triển và cải tiến gần đây

Trong những năm gần đây, khung MITRE ATT&CK đã thấy nhiều **cải tiến đáng kể**, bao gồm: - **Tích hợp với các công cụ tự động hóa:** Những công cụ như **Senseon** tích hợp khung MITRE ATT&CK vào các nền tảng phát hiện, phân loại, điều tra và phản ứng mối đe dọa tự động, nâng cao tốc độ và độ chính xác của việc phân tích mối đe dọa[5]. - **Công cụ hình ảnh nâng cao:** Các nền tảng như **Datadog's Cloud SIEM** cung cấp bản đồ nhiệt tương tác và bảng bên cung cấp cái nhìn trực tiếp về các quy tắc phát hiện và độ bao phủ của chúng, giúp các đội ngũ bảo mật xác định các khoảng trống trong chiến lược bảo mật của họ[1].

1.5. Các thực tiễn tốt nhất khi triển khai MITRE ATT&CK

Để triển khai hiệu quả MITRE ATT&CK trong một SOC: - **Sử dụng thuật ngữ tiêu chuẩn hóa:** Đảm bảo rằng tất cả các đội ngũ bảo mật đều sử dụng thuật ngữ tiêu chuẩn hóa từ khung MITRE ATT&CK để tạo thuận lợi cho việc giao tiếp rõ ràng và tương quan dữ liệu về mối đe dọa[3]. - **Cập nhật thường xuyên cơ sở kiến thức:** Giữ cho kiến thức luôn được cập nhật với những bổ sung và cập nhật mới nhất từ cơ sở kiến thức MITRE ATT&CK để phản ánh sự thay đổi của các cảnh báo về mối đe dọa[5].

Bằng cách hiểu và tận dụng những thành phần này cùng với các thực tiễn tốt nhất, các SOC có thể tăng cường khả năng phát hiện, phân tích và phản ứng hiệu quả với các mối đe dọa mạng.

Tài liệu tham khảo

- [1] Datadog Blog: “Identify Gaps to Strengthen Detection Coverage With the Datadog Cloud SIEM MITRE ATT&CK Map”
- [3] Cato Learning Center: “Using the MITRE ATT&CK Dashboard”
- [5] Senseon Blog: “Automating The MITRE ATT&CK Framework”

2. Vai Trò của MITRE ATT&CK trong Trung Tâm Hoạt Động An Ninh (SOC)

Tổng Quan về MITRE ATT&CK trong SOC

Khung MITRE ATT&CK đóng vai trò quan trọng trong việc nâng cao khả năng của một **Trung Tâm Hoạt Động An Ninh (SOC)** bằng cách cung cấp một phương pháp có cấu trúc để hiểu và bảo vệ chống lại các mối đe dọa mạng. Dưới đây là những khía cạnh chính về cách MITRE ATT&CK được tích hợp vào một SOC:

1. **Tích hợp Thông Tin Đe Dọa:** MITRE ATT&CK phục vụ như một cơ sở tri thức toàn diện cho **thông tin đe dọa**. Nó vạch ra các hành động, kỹ thuật và quy trình (TTPs) được sử dụng bởi kẻ xấu, giúp đội ngũ SOC theo kịp các mối đe dọa mới nổi[1].
2. **Căn Cứ Tác Chiến:** Bằng cách đồng bộ hóa với khung MITRE ATT&CK, các nhóm SOC có thể xác định chính xác các phương pháp được kẻ tấn công sử dụng. Sự căn cứ này là rất cần thiết cho các đội ngũ an ninh, giúp họ phát hiện và giảm thiểu các mối đe dọa một cách hiệu quả[1].
3. **Nâng Cao Phản Ứng Sự Cố:** Hiểu biết về khung MITRE ATT&CK cho phép các nhân viên phản ứng sự cố xác định hiệu quả các dấu hiệu của một cuộc tấn công, rút ngắn thời gian phản ứng. Khung này thúc đẩy sự hợp tác tốt hơn giữa các đội phòng thủ mạng khi xử lý sự cố an ninh, cho phép nhanh chóng và hiệu quả trong việc trung hòa các mối đe dọa[1].

Vai Trò trong Phát Hiện và Liên Kết Mỗi Đe Dọa

1. **Phát Hiện Mỗi Đe Dọa:** Khung MITRE ATT&CK phác thảo các hành động cụ thể mà các kẻ thù thực hiện để đạt được mục tiêu tác chiến của họ. Những kỹ thuật này thể hiện tính linh hoạt trong các chiến thuật của kẻ thù, có thể được sử dụng để đạt được nhiều mục tiêu khác nhau. Đối với mỗi kỹ thuật trong khung, có các nghiên cứu trường hợp thực tế, dấu hiệu vi phạm an ninh (**indicators of compromise**), và các chiến lược ngăn chặn đi kèm. Điều này hỗ trợ trong việc phát hiện chính xác và phản ứng với các mối đe dọa tiềm năng[1].
2. **Liên Kết với SIEM và EDR:** Việc tích hợp MITRE ATT&CK với các hệ thống **Quản Lý Thông Tin và Sự Kiện An Ninh (SIEM)** và các công cụ **Phát Hiện và Phản Ứng Điểm Cuối (EDR)** nâng cao khả năng phát hiện và tương quan các mối đe dọa. Ví dụ, việc sử dụng **PowerShell** để tiêm mã vào **SQL.exe** với mục đích lấy cắp thông tin xác thực là một ví dụ thực tế về cách các kỹ thuật phụ khác nhau có thể được thực hiện cùng nhau[1][3].

Bắt Chước Kẻ Thù và Đào Tạo

1. **Bắt Chước Kẻ Thù:** Các bài tập mô phỏng hành vi của kẻ thù tái hiện các cuộc tấn công mạng thực tế nhằm phát hiện các lỗ hổng trong các quy trình an ninh. Khi các bài tập này dựa trên khung MITRE ATT&CK, chúng nâng cao khả năng phòng thủ của tổ chức bằng cách phản ánh chính xác các chiến thuật và hành vi của kẻ thù mạng. Các công cụ như **Caldera** và **Atomic Red Team** cung cấp nguồn tài nguyên toàn diện để bắt chước các kỹ thuật cụ thể được sử dụng bởi các kẻ thù, giúp đánh giá độ bền vững của các phương pháp phòng thủ trong một mạng lưới mục tiêu một cách hiệu quả[1].
2. **Đào Tạo và Phát Triển Kỹ Năng:** Đào tạo các nhà phân tích SOC về khung MITRE ATT&CK là rất quan trọng cho việc phát triển kỹ năng của họ. Điều này bao gồm việc hiểu các chiến thuật, kỹ thuật, và quy trình được nêu trong khung, cũng như các bài tập thực hành mô phỏng các cuộc tấn công thực tế. Đào tạo này giúp các nhà phân tích nhận diện các kỹ thuật của kẻ thù và phát triển các chiến lược để đối phó với chúng[1][3].

Hợp Tác với Các Đội Khác

1. **Hợp Tác Liên Ngành:** Khung MITRE ATT&CK thúc đẩy việc trao đổi thông tin đe dọa giữa các tổ chức, nâng cao nỗ lực an ninh mạng trên quy mô rộng. Sự hợp tác này là rất quan trọng để đảm bảo rằng tất cả các đội trong một tổ chức đều được đồng bộ hóa với thông tin đe dọa và các thực tiễn tốt nhất mới nhất[1].
2. **Sự Đồng Bộ với Các Tiêu Chuẩn Ngành:** Khung này được sử dụng

kết hợp với các tiêu chuẩn ngành khác như **NIST** và **ISO 27001**. Sự đồng bộ này đảm bảo rằng các hoạt động an ninh không chỉ hiệu quả mà còn tuân thủ các yêu cầu quy định[3][5].

Kết Luận

Khung MITRE ATT&CK là một tài sản quan trọng cho bất kỳ SOC nào, cung cấp một phương pháp có cấu trúc để hiểu và bảo vệ chống lại các mối đe dọa mạng. Sự tích hợp của nó nâng cao thông tin đe dọa, phản ứng sự cố và tư thế bảo mật tổng thể bằng cách đồng bộ với các tiêu chuẩn ngành và thúc đẩy hợp tác liên ngành. Bằng cách tận dụng các kỹ thuật và chiến thuật được nêu trong khung, các đội SOC có thể cải thiện khả năng phát hiện và phản ứng, từ đó củng cố khả năng phòng thủ trước các kẻ thù mạng tinh vi.

Tài Liệu Tham Khảo

- [1] Đề tài tham khảo
- [3] Tài liệu về Threat Hunting
- [5] Tiêu chuẩn ISO 27001

3. Hiểu Rõ Cấu Trúc Framework MITRE ATT&CK

Framework MITRE ATT&CK là hướng dẫn toàn diện giúp hiểu rõ về các chiến thuật và kỹ thuật của kẻ thù, được thiết kế nhằm nâng cao khả năng của tổ chức trong việc nhận diện và giảm thiểu các mối đe dọa mạng. Dưới đây là phân tích chi tiết về cấu trúc của nó:

Tactics (Chiến Thuật)

- **Chiến thuật của kẻ thù:** Đây là những mục tiêu cấp cao mà kẻ tấn công cố gắng đạt được trong suốt một cuộc tấn công. Framework MITRE ATT&CK phân loại các chiến thuật này thành nhiều giai đoạn trong vòng đời tấn công, bao gồm:
 - **Reconnaissance:** Thu thập thông tin về mục tiêu.
 - **Resource Development:** Tiến hành phát triển nguồn lực cần thiết cho cuộc tấn công.
 - **Initial Access:** Gaining access to the target's system or network.
 - **Execution:** Thực hiện cuộc tấn công.
 - **Persistence:** Duy trì quyền truy cập vào hệ thống hoặc mạng.
 - **Privilege Escalation:** Nâng cao quyền hạn để kiểm soát nhiều hơn.
 - **Defense Evasion:** Tránh bị phát hiện bởi các biện pháp bảo mật.
 - **Credential Access:** Lấy được thông tin xác thực hợp lệ.
 - **Discovery:** Xác định dữ liệu hoặc tài nguyên quý giá.
 - **Lateral Movement:** Di chuyển trong mạng để đến các mục tiêu có giá trị hơn.
 - **Collection:** Thu thập dữ liệu hoặc tài nguyên.

- **Command and Control:** Thiết lập các kênh liên lạc với kẻ tấn công.
- **Exfiltration:** Rút dữ liệu khỏi hệ thống hoặc mạng.
- **Impact:** Gây thiệt hại hoặc gián đoạn.
- **Termination:** Kết thúc cuộc tấn công[1][3].

Techniques (Kỹ Thuật)

- **Hành Động Cụ Thể:** Đây là các phương pháp cụ thể được sử dụng để đạt được các chiến thuật của kẻ thù. Mỗi kỹ thuật được chi tiết hóa với các chỉ số chứng minh (IoCs) và các chiến lược phòng ngừa. Các kỹ thuật có thể được phân loại thành các tiểu kỹ thuật, cung cấp cái nhìn chi tiết về cách thức thực hiện các cuộc tấn công[1][3].

Procedures (Thủ Tục)

- **Phương Pháp Rõ Ràng:** Đây là các minh chứng cụ thể về cách mà các kỹ thuật xuất hiện trong các cuộc tấn công thực tế. Thủ tục cung cấp hướng dẫn từng bước về cách các kẻ thù thực hiện các kỹ thuật cụ thể, chẳng hạn như sử dụng PowerShell để tiêm mã vào SQL.exe nhằm lấy thông tin xác thực[1].

Matrices (Ma Trận)

- **Ma Trận ATT&CK:** Framework trình bày dữ liệu của mình trong các ma trận, trong đó các chiến thuật được liệt kê ở dưới cùng và các kỹ thuật liên quan được phân loại ở phía trên. Cấu hình này thuận lợi cho việc giải thích các phương thức tấn công khác nhau khi chúng diễn ra trong các sự cố thực tế[1][3].

Ứng Dụng Thực Tế

Để sử dụng hiệu quả framework MITRE ATT&CK, bạn cần ánh xạ các mối đe dọa đã được xác định đến các chiến thuật và kỹ thuật này. Dưới đây là cách thức thực hiện:

1. **Xác Định Mối Đe Dọa:** Sử dụng các công cụ bảo mật của bạn để nhận diện các hoạt động nghi ngờ và ánh xạ chúng với ma trận MITRE ATT&CK.
2. **Phân Tích Chiến Thuật:** Xác định các chiến thuật nào đang được kẻ tấn công sử dụng dựa trên các mối đe dọa đã xác định.
3. **Phân Đoạn Kỹ Thuật:** Phân tích các kỹ thuật cụ thể đang được sử dụng để đạt được các chiến thuật đã xác định.
4. **Đi Sâu vào Thủ Tục:** Hiểu các thủ tục mà kẻ tấn công sử dụng để thực hiện các kỹ thuật này.

Ví dụ, nếu bạn xác định hoạt động PowerShell nghi ngờ, bạn có thể ánh xạ nó đến chiến thuật “Execution” và sau đó phân tích nó thành các kỹ thuật cụ thể

như “Command and Control” hoặc “Credential Access.” Bằng cách đi sâu hơn, bạn có thể xác định các thủ tục được sử dụng, chẳng hạn như tiêm mã vào SQL.exe[1][3].

Công Cụ và Công Nghệ

Một số công cụ và công nghệ hỗ trợ việc tích hợp MITRE ATT&CK vào SOC của bạn:

1. **SentinelOne:** Cung cấp một agent EDR và ITDR thống nhất, giúp bảo vệ danh tính mạnh mẽ và cung cấp cái nhìn sâu sắc về các hoạt động của endpoint. Nó tích hợp với framework MITRE ATT&CK để nâng cao khả năng phát hiện và phản ứng với các mối đe dọa[2].
2. **Cato Networks:** Cung cấp một bảng điều khiển ánh xạ các mối đe dọa được xác định bởi dịch vụ IPS của họ đến các chiến thuật và kỹ thuật trong ma trận MITRE ATT&CK. Bảng điều khiển này cung cấp nhiều widget để hiển thị và phân tích, bao gồm tóm tắt về các chiến thuật, phân tích kỹ thuật và phân bố thiết bị[3].

Thách Thức và Hạn Chế

Mặc dù framework MITRE ATT&CK rất hiệu quả, nó cũng gặp một số thách thức:

1. **Đào Tạo Toàn Diện:** Cần có kiến thức chuyên môn và đào tạo toàn diện để sử dụng framework hiệu quả.
2. **Tiêu Tồn Tài Nguyên:** Đòi hỏi một đầu tư đáng kể về thời gian và tài nguyên để khớp dữ liệu hiện tại một cách hợp lý.
3. **Độ Phức Tạp Dữ Liệu:** Sự đa dạng của các kết hợp dữ liệu trong framework mang đến những khó khăn đặc biệt cho các tổ chức cố gắng khớp dữ liệu hiện tại của họ, đặc biệt là khi nói đến các chiến thuật truy cập ban đầu[1].

Hướng Phát Triển Tương Lai

Framework MITRE ATT&CK tiếp tục phát triển với các kỹ thuật và chiến thuật mới được thêm vào thường xuyên. Để đi trước, việc thường xuyên xem xét và xác thực phạm vi hiện tại của bạn là cần thiết. Mô phỏng Tấn công và Xâm nhập (Breach and Attack Simulation - BAS) có thể là một yếu tố thúc đẩy mạnh mẽ trong việc đưa vào hoạt động của framework bằng cách giảm bớt nỗ lực thủ công và liên tục đo lường, cải thiện tư thế bảo mật của bạn[5].

Kết Luận

Hiểu rõ cấu trúc của framework MITRE ATT&CK là điều thiết yếu đối với bất kỳ SOC nào. Bằng cách ánh xạ các mối đe dọa đến các chiến thuật và kỹ thuật, phân tích chúng một cách chi tiết, và sử dụng các công cụ và công nghệ hỗ trợ, bạn có thể nâng cao khả năng của tổ chức trong việc nhận diện và giảm thiểu

các mối đe dọa mạng một cách hiệu quả. Đào tạo và cập nhật định kỳ là rất quan trọng để vượt qua những thách thức mà framework toàn diện này đặt ra.

4. Tình báo Đe dọa và Tương quan với MITRE ATT&CK

Giới thiệu về Tình báo Đe dọa và MITRE ATT&CK

Tình báo đe dọa là một thành phần quan trọng trong bảo mật mạng hiện đại, cung cấp cái nhìn về các mối đe dọa tiềm tàng cùng với các chiến thuật, kỹ thuật và quy trình (TTPs) của chúng. Khung MITRE ATT&CK là một cơ sở kiến thức được công nhận toàn cầu, phân loại các TTP của kẻ thù, đóng vai trò như một công cụ thiết yếu để tương quan tình báo đe dọa với hành vi tấn công thực tế[3][5].

Tương quan Tình báo Đe dọa với MITRE ATT&CK

Việc tương quan tình báo đe dọa với khung MITRE ATT&CK bao gồm một số bước chính:

1. **Thu thập Dữ liệu:** Thu thập tình báo đe dọa từ nhiều nguồn khác nhau, bao gồm tình báo mã nguồn mở (OSINT), tình báo mã nguồn kín (CSIT), và dữ liệu bảo mật nội bộ. Dữ liệu này nên bao gồm các chỉ số xâm nhập (IOCs), chẳng hạn như địa chỉ IP, tên miền và băm phần mềm độc hại[1][5].
2. **Phân tích Dữ liệu:** Sử dụng các thuật toán dựa trên machine learning và AI để phân tích dữ liệu thu thập được. Những thuật toán này có thể xác định các mẫu và dị thường cho thấy các mối đe dọa tiềm tàng. Ví dụ, việc sử dụng các mô hình hỗn hợp Gaussian để thiết lập phân phối chuẩn đa chiều của hành vi mạng bình thường có thể giúp phát hiện những sai lệch cho thấy có thể xảy ra tấn công[1].
3. **Lập bản đồ tới MITRE ATT&CK:** Khi dữ liệu đã được phân tích, tiến hành lập bản đồ các mối đe dọa đã xác định tới các kỹ thuật và chiến thuật tương ứng trong khung MITRE ATT&CK. Việc này liên quan đến việc sử dụng các công cụ và nền tảng có thể tự động phân loại các mối đe dọa được phát hiện theo các kỹ thuật ATT&CK dựa trên đặc điểm hành vi[3][5].
4. **Ưu tiên Cảnh báo:** Ưu tiên các cảnh báo dựa trên sự tương quan với các kỹ thuật MITRE ATT&CK. Điều này có thể thực hiện thông qua việc sử dụng các thuật toán đánh giá đa yếu tố tích hợp ngữ cảnh lỗ hổng dựa trên CVE, siêu dữ liệu phân loại tài sản và tương quan tình báo đe dọa với các mức độ tin cậy và độ tin cậy cấu hình[1].

Triển khai Thực tiễn

Để triển khai tương quan tình báo đe dọa với MITRE ATT&CK, bạn có thể sử dụng các công cụ và kỹ thuật sau:

1. **Chuỗi Kỹ thuật ATT&CK Tự động:** Sử dụng các công cụ như Senseon tích hợp khung MITRE ATT&CK vào các nền tảng phát hiện, điều tra và phản ứng tự động với các mối đe dọa. Những công cụ này có thể tự động phân loại các sự kiện thực tế theo các kỹ thuật trong khung MITRE ATT&CK, nâng cao tốc độ và độ chính xác của phân tích mối đe dọa[5].
2. **Tương quan Dựa trên Đồ thị:** Tận dụng kỹ thuật tương quan dựa trên đồ thị để xác định các sự kiện liên quan tạo thành chuỗi tấn công. Điều này có thể được thực hiện bằng cách sử dụng các công cụ hỗ trợ các mẫu hành vi đa giai đoạn phức tạp với các mối quan hệ tạm thời, ngưỡng thống kê và tổng hợp thông tin dựa trên ngữ cảnh[1].
3. **Nền tảng Tình báo Đe dọa:** Tận dụng các nền tảng tình báo đe dọa cung cấp dữ liệu mối đe dọa theo thời gian thực và tích hợp chúng với khung MITRE ATT&CK. Ví dụ, dịch vụ MDR của SentinelOne sử dụng tình báo đe dọa để nhận diện và phản ứng với các hoạt động nghi ngờ, tận dụng tối đa sức mạnh của công nghệ đầu cuối và khối lượng công việc đám mây[2].

Ví dụ Về Lệnh CLI và Tập Cấu hình

Mặc dù các lệnh CLI và tập cấu hình cụ thể có thể khác nhau tùy thuộc vào công cụ hoặc nền tảng đang được sử dụng, dưới đây là một ví dụ về cách bạn có thể cấu hình một công cụ như Senseon để tích hợp với khung MITRE ATT&CK:

```
# Ví dụ về tập cấu hình cho Senseon
{
  "threat_intelligence": {
    "sources": [
      {
        "name": "OSINT",
        "url": "https://example-osint.com"
      },
      {
        "name": "CSIT",
        "url": "https://example-csit.com"
      }
    ],
    "mapping": {
      "techniques": [
        {
          "name": "T1059",
          "description": "Command and Control"
        },
        {
          "name": "T1071",
```

```

        "description": "Application Layer Protocol"
    }
]
}
}
}

```

Tệp cấu hình này thiết lập các nguồn tình báo đe dọa và lập bản đồ chúng tới các kỹ thuật MITRE ATT&CK cụ thể, đảm bảo rằng nền tảng có thể tương quan các mối đe dọa được phát hiện với các kỹ thuật ATT&CK liên quan.

Kết luận

Việc tương quan tình báo đe dọa với khung MITRE ATT&CK là điều cần thiết cho các hoạt động bảo mật hiệu quả. Bằng cách tận dụng các công cụ tự động, tương quan dựa trên đồ thị và tích hợp với các nền tảng tình báo đe dọa, các tổ chức có thể nâng cao khả năng phát hiện và phản ứng với các mối đe dọa trong thời gian thực. Cách tiếp cận này không chỉ cải thiện độ chính xác của phân tích mối đe dọa mà còn căn chỉnh các chiến lược bảo mật với hành vi của kẻ thù, cung cấp một hệ thống phòng thủ vững chắc chống lại các mối đe dọa mạng hiện đại[1][3][5].

5. Triển khai MITRE ATT&CK trong các Quy trình của SOC

5.1. Căn chỉnh Quy trình SOC với Khung MITRE ATT&CK

Để triển khai hiệu quả khung MITRE ATT&CK trong Trung tâm Vận hành Bảo mật (SOC), việc căn chỉnh các quy trình của bạn với cấu trúc của khung là vô cùng quan trọng. Điều này bao gồm việc hiểu rõ các **tactics**, **techniques**, và **procedures** (TTPs) được phác thảo trong khung và ánh xạ chúng tới các hoạt động bảo mật hiện có của bạn.

- **Xác định các TTP liên quan:** Tập trung vào các tactics và techniques phù hợp nhất với bối cảnh mối đe dọa của tổ chức bạn. Khung MITRE ATT&CK bao gồm 14 tactics và 203 techniques, có thể gây áp lực cho bạn. Hãy ưu tiên bằng cách xác định các đối tượng tấn công có khả năng cao sẽ nhắm đến tổ chức của bạn và các tactics mà họ thường sử dụng[3].
- **Sử dụng ATT&CK Navigator:** ATT&CK Navigator là một công cụ do MITRE cung cấp giúp lập bản đồ các chiến lược phòng thủ chống lại các kỹ thuật khác nhau. Công cụ này mang đến những góc nhìn quan trọng hỗ trợ các chuyên gia bảo mật trong việc củng cố các biện pháp bảo vệ của họ[5].

5.2. Tích hợp Threat Intelligence với MITRE ATT&CK

Threat intelligence là một thành phần quan trọng trong việc triển khai khung MITRE ATT&CK. Bằng cách tích hợp threat intelligence với khung, bạn có thể xây dựng danh sách ưu tiên các phương pháp phát hiện và chiến lược giảm thiểu.

- **Xác định các Nhóm đối thủ:** Sử dụng danh sách công khai về các nhóm đối thủ và phần mềm độc hại do MITRE duy trì để xác định nhóm nào có khả năng nhắm đến tổ chức của bạn dựa trên ngành nghề và bối cảnh mối đe dọa[3].
- **Liên kết Threat Intelligence với TTPs:** Liên kết threat intelligence đã xác định với các TTP được phác thảo trong khung MITRE ATT&CK. Điều này giúp tạo ra một hiểu biết toàn diện về các mối đe dọa tiềm tàng và các chiến lược giảm thiểu tương ứng[5].

5.3. Triển khai Khung MITRE ATT&CK với Mô phỏng Tấn công và Xâm nhập (BAS)

Mô phỏng Tấn công và Xâm nhập (BAS) có thể tăng tốc đáng kể việc triển khai khung MITRE ATT&CK bằng cách giảm thiểu nỗ lực thủ công và liên tục đo lường và cải thiện thể trận bảo mật của bạn.

- **Tự động hóa các tác vụ cấp thấp:** Các giải pháp BAS tự động hóa những tác vụ lặp đi lặp lại và tốn thời gian như kiểm tra các kỹ thuật giống nhau hàng ngày, cho phép các đội đổ tập trung vào các mô phỏng tấn công phức tạp hơn và sáng tạo hơn[3].
- **Tùy chỉnh kịch bản tấn công:** Sử dụng các công cụ như **Picus Security Control Validation Threat Builder** để thiết kế các kịch bản tấn công tùy chỉnh thông qua giao diện kéo và thả đơn giản. Tính năng này cho phép bạn điều chỉnh các mô phỏng của mình theo các kịch bản và môi trường tấn công cụ thể[3].

5.4. Các bước Triển khai Thực tế

Dưới đây là một số bước thực tế để triển khai khung MITRE ATT&CK trong các quy trình SOC của bạn:

- **Phác thảo Môi trường SOC với Khung ATT&CK:** Phác thảo môi trường SOC của bạn với khung MITRE ATT&CK để xác định các lĩnh vực cần cải thiện và tối ưu hóa thể trận bảo mật của bạn. Điều này bao gồm việc hiểu rõ cấu trúc, nhân sự, phạm vi và công cụ trong SOC của bạn[1].
- **Đánh giá Tình hình Hiện tại của SOC:** Đánh giá tình hình hiện tại của SOC của bạn để phát hiện các điểm yếu tiềm ẩn và xác định các lĩnh vực cần cải thiện. Kiến thức cơ bản này là rất quan trọng để xác định cách mà khung ATT&CK có thể đáp ứng các nhu cầu cụ thể[1].

- **Phát triển các Phương pháp Phát hiện:** Phát triển các phương pháp phát hiện hiệu quả và chính xác bằng cách liên kết các phát hiện với khung ATT&CK. Điều này đảm bảo rằng SOC của bạn sẵn sàng phát hiện và ứng phó với các mối đe dọa mới nổi một cách hiệu quả[1].

Ví dụ về CLI và Tập tin Cấu hình

Khi các lệnh CLI và tập tin cấu hình cụ thể có thể khác nhau tùy theo các công cụ và công nghệ sử dụng, dưới đây là một số ví dụ liên quan đến việc triển khai khung MITRE ATT&CK:

- **Sử dụng ATT&CK Navigator:**

```
# Lệnh ví dụ để khởi động ATT&CK Navigator
attck-navigator --help
```

Để biết thêm chi tiết về cách sử dụng, tham khảo tài liệu chính thức do MITRE cung cấp[5].

- **Tùy chỉnh Kịch bản Tấn công với Các Công cụ BAS:**

```
# Đoạn mã ví dụ sử dụng Picus Security Control Validation Threat Builder
from picus_threat_builder import ThreatBuilder
```

```
threat_builder = ThreatBuilder()
threat_builder.add_technique("T1059", "Giao diện Command và Scripting")
threat_builder.add_technique("T1087", "Dịch vụ Windows")
threat_builder.build_attack_scenario()
```

Để biết thêm ví dụ chi tiết, tham khảo tài liệu chính thức do Picus Security cung cấp[3].

Các Công cụ và Công nghệ Hỗ trợ Tích hợp MITRE ATT&CK

Một số công cụ và công nghệ hỗ trợ tích hợp khung MITRE ATT&CK vào quy trình SOC của bạn bao gồm:

- **ATT&CK Navigator:** Một công cụ do MITRE cung cấp để lập bản đồ các chiến lược phòng thủ chống lại các kỹ thuật khác nhau[5].
- **Picus Security Control Validation (SCV):** Một module mô phỏng các mối đe dọa mạng thực tế để tự động và liên tục đánh giá hiệu quả của các biện pháp bảo mật của bạn[3].
- **Caldera và Atomic Red Team:** Các công cụ mô phỏng các kỹ thuật cụ thể được sử dụng bởi các đối thủ, nâng cao khả năng phòng thủ của một tổ chức bằng cách phản ánh các tactics và hành vi của đối thủ mạng thực tế[5].

Thách thức và Hạn chế

Việc tích hợp khung MITRE ATT&CK có thể gặp nhiều thách thức, bao gồm yêu cầu đào tạo toàn diện và kiến thức chuyên môn, cũng như cần một khoản đầu tư đáng kể về thời gian và nguồn lực. Nhiều cách kết hợp dữ liệu khác nhau trong khung đặt ra khó khăn đặc biệt cho các tổ chức cố gắng khớp dữ liệu hiện tại của họ, đặc biệt là khi liên quan đến các tactics truy cập ban đầu[5].

Hướng đi Tương lai và Cải tiến

Khung MITRE ATT&CK đang liên tục phát triển để giải quyết các mối đe dọa mới và đang nổi lên. Những hướng đi tương lai bao gồm nâng cao tự động hóa threat intelligence, phân tích rủi ro mạng định lượng, cũng như đo lường và phân tích các lỗ hổng[2].

Bằng cách thực hiện các bước này và tận dụng các công cụ và công nghệ phù hợp, bạn có thể triển khai hiệu quả khung MITRE ATT&CK trong các quy trình SOC của mình, nâng cao khả năng bảo mật của tổ chức và cải thiện khả năng phản ứng với các sự cố.

6. Phản ứng sự cố và MITRE ATT&CK: Hướng dẫn thực tiễn

1. Tích hợp MITRE ATT&CK trong Phản ứng sự cố

MITRE ATT&CK là một khuôn khổ toàn diện cung cấp cách tiếp cận có cấu trúc để hiểu các chiến thuật, kỹ thuật và quy trình (TTPs) của kẻ tấn công. Việc tích hợp MITRE ATT&CK vào quy trình phản ứng sự cố (IR) nâng cao hiệu quả của hoạt động bảo mật bằng cách căn chỉnh các chiến lược IR với hành vi của mối đe dọa trong thực tế[3][5].

2. Cách tiếp cận từng giai đoạn trong Phản ứng sự cố với MITRE ATT&CK

Một kế hoạch phản ứng sự cố được xây dựng tốt cần bao gồm các giai đoạn tương ứng với khuôn khổ MITRE ATT&CK. Dưới đây là hướng dẫn thực tiễn để tích hợp MITRE ATT&CK vào từng giai đoạn:

Chuẩn bị

- **Tích hợp thông tin tình báo về mối đe dọa:** Sử dụng MITRE ATT&CK để xác định các mối đe dọa tiềm ẩn và ưu tiên phát hiện dựa trên TTPs của kẻ tấn công. Điều này liên quan đến việc lập bản đồ các nhóm mối đe dọa với các kỹ thuật và chiến thuật mà họ thường sử dụng[3].
- **Đánh giá kiểm soát:** Đánh giá các kiểm soát bảo mật hiện có dựa trên các kỹ thuật của MITRE ATT&CK để xác định các điểm yếu và lỗ hổng. Điều này giúp củng cố hệ thống phòng thủ một cách chủ động[1].

Phát hiện & Phân tích

- **Phân tích chỉ số xâm phạm (IoC):** Sử dụng MITRE ATT&CK để phân tích IoCs và xác định các bất thường có thể chỉ ra hoạt động độc hại. Điều này liên quan đến việc tương quan các chỉ số phát hiện được với các hành vi đã biết của kẻ tấn công[1][3].
- **Thu thập chứng cứ pháp lý:** Bảo quản nhật ký và các bản chụp hệ thống để hỗ trợ điều tra và tuân thủ quy định. Dữ liệu này có thể được sử dụng để lập bản đồ các hành vi quan sát được với các kỹ thuật của MITRE ATT&CK, cung cấp bối cảnh cho sự cố[1].

Giới hạn & Xử lý

- **Giới hạn dựa trên chiến thuật:** Triển khai các biện pháp giới hạn dựa trên các chiến thuật và kỹ thuật đã xác định. Ví dụ, nếu kẻ tấn công đang sử dụng phương thức di chuyển ngang (T1021), hãy cách ly các hệ thống bị ảnh hưởng để ngăn chặn sự lây lan thêm[3].
- **Khắc phục theo kỹ thuật cụ thể:** Phát triển các bước khắc phục phù hợp với các kỹ thuật cụ thể mà kẻ tấn công đã sử dụng. Điều này đảm bảo rằng tất cả các hành động liên quan đều được thực hiện để loại bỏ mối đe dọa[3].

Khôi phục & Kinh nghiệm rút ra

- **Xem xét sau sự cố:** Tiến hành xem xét kỹ lưỡng sự cố bằng cách sử dụng khuôn khổ MITRE ATT&CK. Điều này liên quan đến việc lập bản đồ các hành vi quan sát được với khuôn khổ để hiểu rõ về các chiến thuật và kỹ thuật mà kẻ tấn công đã sử dụng[4].
- **Cải tiến quy trình:** Tích hợp các phát hiện từ việc xem xét sau sự cố vào các chiến lược quản lý rủi ro lớn hơn. Điều này bao gồm cập nhật các kiểm soát bảo mật, tinh chỉnh quy tắc phát hiện và nâng cao đào tạo cho các nhà phân tích SOC[5].

3. Ví dụ thực tiễn và Công cụ

Mô phỏng xâm nhập và tấn công (BAS) Các giải pháp BAS có thể mô phỏng các cuộc tấn công trong thực tế dựa trên các kỹ thuật của MITRE ATT&CK, giúp các đội bảo mật đánh giá được khả năng phòng thủ và xác định các lỗ hổng. Ví dụ, Picus SCV cung cấp SLA 24 giờ để thêm các mối đe dọa mới nổi, cho phép mô phỏng nhanh các vector tấn công mới[3].

Tự động hóa chuỗi kỹ thuật ATT&CK Các công cụ như những công cụ do Dr. Martin Eian phát triển có thể tự động hóa quy trình chuỗi các kỹ thuật ATT&CK, cung cấp cái nhìn tổng quan hơn về hành vi của kẻ tấn công. Điều này liên quan đến việc kết hợp mô hình ngữ nghĩa với các phương pháp lấy dữ liệu để dự đoán các bước tiếp theo có thể xảy ra của kẻ tấn công[4].

4. Kết luận

Việc tích hợp MITRE ATT&CK vào quy trình phản ứng sự cố nâng cao hiệu quả của hoạt động bảo mật bằng cách cung cấp một cách tiếp cận có cấu trúc để hiểu và phản ứng với các mối đe dọa trong thực tế. Bằng cách căn chỉnh các chiến lược IR với khuôn khổ MITRE ATT&CK, các tổ chức có thể cải thiện khả năng phát hiện, giới hạn và loại bỏ các mối đe dọa mạng.

Tài liệu tham khảo: - [1] Frame Group: How to Build a Cyber Incident Response Plan: A Step-by-Step Guide - [3] Picus Security: Operationalizing MITRE ATT&CK with Breach and Attack Simulation - [4] FIRST Conference: Automated ATT&CK Technique Chaining - [5] Protecht Group: Incident Response Guide: Handling Cybersecurity Challenges

7. Xây Dựng Chiến Lược Giám Sát An Ninh Sử Dụng MITRE ATT&CK

Giới thiệu

Việc xây dựng **chiến lược giám sát an ninh** sử dụng khung MITRE ATT&CK bao gồm việc tích hợp các chiến thuật và kỹ thuật của khung này vào Trung tâm Vận hành An ninh (SOC) của bạn nhằm nâng cao khả năng phát hiện và phản ứng với các mối đe dọa. Phần này sẽ tập trung vào các chiến lược và công cụ thực tiễn hỗ trợ tích hợp, đảm bảo rằng SOC của bạn được trang bị tốt để xử lý các mối đe dọa mạng hiện đại.

Hiểu Về Các Ma Trận MITRE ATT&CK

Khung MITRE ATT&CK cung cấp nhiều ma trận được thiết kế cho các môi trường khác nhau, bao gồm Ma Trận Doanh Nghiệp, Ma Trận Di Động, và Ma Trận ICS. Mỗi ma trận nêu rõ các chiến thuật và kỹ thuật cụ thể mà đối thủ có thể sử dụng trong các bối cảnh khác nhau[5].

Tích Hợp MITRE ATT&CK Với Hệ Thống SIEM

Để phát triển các **chiến lược giám sát an ninh** hiệu quả, việc tích hợp khung MITRE ATT&CK với hệ thống SIEM (Quản lý Thông tin và Sự kiện An ninh) là điều quan trọng. Sự tích hợp này cho phép nâng cao tầm nhìn về các mối đe dọa tiềm ẩn và phân tích quy tắc phát hiện một cách chính xác hơn.

- **Datadog Cloud SIEM:** Datadog Cloud SIEM cung cấp cái nhìn tổng quát về độ bao phủ phát hiện thông qua Bản đồ MITRE ATT&CK. Công cụ này ánh xạ các biện pháp bảo vệ tới các chiến thuật và kỹ thuật của MITRE ATT&CK, cung cấp một bản đồ nhiệt tương tác giúp các đội an ninh đánh giá mức độ bao phủ phát hiện trên các bề mặt tấn công khác nhau[3].

– **Hình Ảnh Và Phân Tích:**

- * Trình trực quan hóa Bản đồ MITRE ATT&CK và bản đồ nhiệt mang đến cái nhìn rõ ràng về độ bao phủ phát hiện, cho phép các đội dễ dàng hình dung việc phát hiện mối đe dọa qua các chiến thuật và kỹ thuật khác nhau.
 - * Số lượng quy tắc phát hiện được hiển thị trên nhiều nguồn nhật ký mà Cloud SIEM phân tích, bao gồm AWS CloudTrail và các nguồn dữ liệu quan trọng khác.
 - * Cái nhìn chính nhấn mạnh các nguồn và quy tắc liên quan mà Cloud SIEM đang phân tích, trong khi cái nhìn phụ mở rộng bao phủ để bao gồm tất cả nội dung được cung cấp sẵn và nội dung tùy chỉnh.
- **Lọc Và Tạo Quy Tắc:**
- * Các nhà phân tích có thể tinh chỉnh phân tích của họ bằng cách sử dụng nhiều bộ lọc như mật độ quy tắc, nguồn nhật ký, trạng thái mặc định, chiến thuật, kỹ thuật, và nền tảng để tập trung vào các lĩnh vực và bề mặt tấn công cụ thể.
 - * Trình soạn thảo quy tắc tùy chỉnh có thể truy cập từ bảng bên trong Bản đồ MITRE ATT&CK, nơi các thẻ chiến thuật và kỹ thuật tự động được điền vào khi tạo quy tắc phát hiện mới[3].

Tăng Cường Độ Bao Phủ Phát Hiện

Để củng cố tư thế an ninh của bạn, việc xác định các khoảng trống trong chiến lược phát hiện và cải thiện độ bao phủ phát hiện là điều cần thiết.

- **Xác Định Khoảng Trống:**
 - Bản đồ MITRE ATT&CK giúp các đội an ninh xác định khoảng trống trong chiến lược bảo mật của họ bằng cách cung cấp cái nhìn rõ ràng về độ bao phủ phát hiện và tạo điều kiện cho phân tích quy tắc phát hiện chính xác hơn[3].
 - Bằng cách phân tích số lượng quy tắc phát hiện và độ bao phủ qua các chiến thuật và kỹ thuật khác nhau, các đội có thể chỉ ra các lĩnh vực mà hệ thống bảo vệ của họ có thể thiếu sót.
- **Tạo Quy Tắc Tùy Chỉnh:**
 - Trình soạn thảo quy tắc tùy chỉnh trong Datadog Cloud SIEM cho phép tạo nhanh các quy tắc phát hiện tùy chỉnh với các thẻ chiến thuật và kỹ thuật đã được nhập sẵn, làm cho quy trình tạo quy tắc trở nên hiệu quả hơn[3].
 - Các quy tắc tùy chỉnh có thể được chỉ định với các phương thức phát hiện, truy vấn tìm kiếm, và điều kiện, đảm bảo rằng các mối đe dọa mới được phát hiện và giảm thiểu hiệu quả.

Triển Khai Thực Tiễn

Dưới đây là hướng dẫn từng bước để triển khai MITRE ATT&CK trong chiến lược giám sát an ninh của SOC của bạn:

1. Cấu Hình Tích Hợp MITRE ATT&CK:

- Tích hợp khung MITRE ATT&CK vào hệ thống SIEM của bạn để ánh xạ các biện pháp bảo vệ tới các chiến thuật và kỹ thuật của MITRE ATT&CK.
- Sử dụng các công cụ như Datadog Cloud SIEM để hình dung độ bao phủ phát hiện và xác định khoảng trống trong chiến lược bảo mật của bạn[3].

2. Thiết Lập Quy Tắc Phát Hiện Tùy Chỉnh:

- Sử dụng trình soạn thảo quy tắc tùy chỉnh để tạo quy tắc phát hiện mới với các thể chiến thuật và kỹ thuật đã được nhập sẵn.
- Chỉ định các phương thức phát hiện, truy vấn tìm kiếm, và điều kiện để đảm bảo phát hiện hiệu quả các mối đe dọa mới[3].

3. Giám Sát Và Phân Tích Mối Đe Dọa:

- Sử dụng Bản đồ MITRE ATT&CK để giám sát và phân tích các mối đe dọa theo thời gian thực.
- Lọc theo nguồn dữ liệu hoặc nền tảng để có cái nhìn rõ ràng hơn về các khoảng trống có thể trong việc bao phủ[3].

4. Tinh Chỉnh Chiến Lược Của Bạn:

- Liên tục tinh chỉnh chiến lược giám sát an ninh của bạn dựa trên thông tin thu được từ Bản đồ MITRE ATT&CK.
- Điều chỉnh các quy tắc và bộ lọc phát hiện khi cần thiết để duy trì sự phù hợp với hành vi tấn công trong thực tế[3].

Bằng cách làm theo các bước này và tận dụng các công cụ như Datadog Cloud SIEM, bạn có thể phát triển một chiến lược giám sát an ninh mạnh mẽ, hiệu quả sử dụng khung MITRE ATT&CK để nâng cao khả năng phát hiện và phản ứng trước các mối đe dọa của SOC.

Kết Luận

Việc xây dựng các **chiến lược giám sát an ninh** sử dụng khung MITRE ATT&CK là rất quan trọng cho các SOC hiện đại. Bằng cách tích hợp khung này với hệ thống SIEM, tạo ra các quy tắc phát hiện tùy chỉnh, và liên tục tinh chỉnh chiến lược của bạn, bạn có thể cải thiện đáng kể khả năng phát hiện và phản ứng trước các mối đe dọa mạng của tổ chức. Cách tiếp cận này đảm bảo rằng SOC của bạn luôn chủ động và được trang bị tốt để xử lý những mối đe dọa đang phát triển trong môi trường an ninh mạng luôn thay đổi.

8. Săn tìm mối đe dọa với khung MITRE ATT&CK

Giới thiệu về Săn tìm Mối đe dọa với MITRE ATT&CK

Săn tìm mối đe dọa (Threat hunting) là một phương pháp chủ động nhằm xác định và giảm thiểu các mối đe dọa chưa được phát hiện trong môi trường của tổ chức. Khung MITRE ATT&CK cung cấp một cấu trúc toàn diện để hiểu rõ về các chiến thuật, kỹ thuật, và quy trình (TTPs) của kẻ tấn công. Phần này sẽ phân tích chi tiết việc sử dụng khung MITRE ATT&CK cho săn tìm mối đe

dọa, tập trung vào những phát triển gần đây và các ứng dụng thực tiễn.

Khai thác các Mô hình Ngôn ngữ Lớn (LLMs) để Tự động hóa Việc Tạo Quy tắc Sigma

Một trong những tiến bộ gần đây trong săn tìm mối đe dọa là việc sử dụng các **Mô hình Ngôn ngữ Lớn (LLMs)** và **Retrieval-Augmented Generation (RAG)** để tự động hóa việc tạo các quy tắc Sigma cho việc săn tìm các TTP cụ thể trong khung MITRE ATT&CK[1]. Phương pháp này bao gồm các bước sau:

1. **Thu thập Dữ liệu:** Tập hợp dữ liệu môi trường từ các nguồn như Active Directory.
2. **Tạo Quy tắc:** Sử dụng LLMs để phân tích dữ liệu thu thập được và tạo ra các quy tắc Sigma.
3. **Xác thực Quy tắc:** Đảm bảo rằng các quy tắc được tạo ra là chính xác và phù hợp bằng cách tìm kiếm thông tin từ tài liệu ATT&CK và các nguồn khác.

Dưới đây là ví dụ về cách quy trình này có thể được triển khai:

Ví dụ về việc tạo quy tắc Sigma sử dụng LLMs

Agent 1:

- Tìm kiếm các phương pháp phát hiện trong tài liệu ATT&CK
- Phân tích dữ liệu môi trường (vd: nhật ký Active Directory)
- Chuyển giao các phương pháp phát hiện và kết quả phân tích cho Agent 2

Agent 2:

- Tạo quy tắc Sigma dựa trên thông tin nhận được từ Agent 1
- Xác thực quy tắc bằng cách tìm kiếm trong tài liệu hoặc trang web Sigma

Các Bước Triển khai Thực tiễn

1. **Xác định Mục tiêu Săn tìm Mối đe dọa:**
 - Xác định các TTP cụ thể mà bạn muốn săn tìm bằng cách sử dụng khung MITRE ATT&CK.
 - Đặt ra các mục tiêu rõ ràng dựa trên các tài sản có giá trị nhất đối với tổ chức của bạn và tác động tiềm tàng của một cuộc tấn công[3].
2. **Thu thập và Phân tích Dữ liệu:**
 - Thu thập các nhật ký và dữ liệu telemetry liên quan từ các điểm cuối và mạng.
 - Sử dụng các công cụ như **Splunk** để phân tích dữ liệu thu thập được và xác định các mối đe dọa tiềm ẩn[5].
3. **Tạo Quy tắc Tự động:**
 - Sử dụng LLMs và RAG để tự động hóa việc tạo các quy tắc Sigma cho các TTP cụ thể.
 - Tích hợp các quy tắc này vào hệ thống giám sát an ninh của bạn để phát hiện mối đe dọa theo thời gian thực.

4. Tích hợp Thông tin Tình báo Mối đe dọa:

- Kết hợp việc mô hình hóa ngữ nghĩa từ kiến thức của các chuyên gia với các phương pháp dựa trên dữ liệu để nâng cao độ chính xác của việc săn tìm mối đe dọa[2].

5. Giám sát và Cải tiến Liên tục:

- Thường xuyên cập nhật và tinh chỉnh các chiến lược săn tìm mối đe dọa của bạn dựa trên các kỹ thuật tấn công mới và các mối đe dọa đang nổi lên.

Các Công cụ và Công nghệ Hỗ trợ Tích hợp MITRE ATT&CK

Một số công cụ và công nghệ có thể hỗ trợ việc tích hợp MITRE ATT&CK vào quy trình săn tìm mối đe dọa của bạn:

- **Splunk ThreatHunting App:** Ứng dụng này cung cấp một bảng điều khiển phù hợp với khung MITRE ATT&CK, cho phép bạn trực quan hóa và phân tích dữ liệu mối đe dọa theo thời gian thực[5].
- **Quy tắc Sigma:** Những quy tắc này có thể được tạo ra bằng cách sử dụng LLMs và tích hợp vào hệ thống giám sát an ninh của bạn để phát hiện mối đe dọa tự động.

Thách thức và Hạn chế

Mặc dù có các tiến bộ trong việc săn tìm mối đe dọa với MITRE ATT&CK, vẫn có một số thách thức và hạn chế cần xem xét:

- **Dương tính giả:** Tập trung vào tất cả các mức của tháp có thể dẫn đến dương tính giả. Lọc các phương pháp phát hiện là rất quan trọng để giảm dương tính giả[1].
- **Giới hạn kích thước token:** Kích thước token lớn có thể hạn chế quá trình tạo ra của LLMs. Điều chỉnh các thông số token là cần thiết để đạt được hiệu suất tối ưu[1].

Bằng cách hiểu rõ những thách thức này và khai thác các công cụ và công nghệ mới nhất, bạn có thể sử dụng khung MITRE ATT&CK một cách hiệu quả cho việc săn tìm mối đe dọa nâng cao trong Trung tâm Vận hành An ninh của mình.

9. Các Tình Huống Sử Dụng và Nghiên Cứu Tình Huống MITRE ATT&CK Trong Thực Tế

1. Nghiên cứu tình huống: Cuộc tấn công Burrowing

Một nghiên cứu tình huống gần đây liên quan đến cuộc tấn công “Burrowing” cho thấy việc áp dụng các kỹ thuật MITRE ATT&CK trong các tình huống thực tế. Cuộc tấn công này liên quan đến nhiều kỹ thuật MITRE ATT&CK và chỉ số thỏa hiệp (IoCs) đã được quản lý một cách hiệu quả bằng công cụ ATT&CK Navigator[1].

Điểm chính:

- **Kỹ thuật đã sử dụng:** Cuộc tấn công này đã sử dụng các kỹ thuật như **credential dumping**, **lateral movement**, và **data exfiltration**.
- **Phát hiện và phản ứng:** Nhóm SOC đã sử dụng ATT&CK Navigator để lập bản đồ các chiến lược phòng thủ chống lại những kỹ thuật này, cho phép họ củng cố các biện pháp bảo vệ.
- **Phản ứng sự cố:** Việc hiểu biết về khung MITRE ATT&CK đã giúp các người phản ứng sự cố xác định các dấu hiệu của cuộc tấn công một cách hiệu quả hơn, rút ngắn thời gian phản ứng và nâng cao tinh thần đồng đội giữa các nhóm phòng thủ mạng[1].

2. Tự động hóa chuỗi kỹ thuật ATT&CK

Nghiên cứu của Tiến sĩ Martin Eian tại công ty mnemonic tập trung vào việc tự động hóa việc phát hiện các hành vi của kẻ thù sử dụng cơ sở kiến thức MITRE ATT&CK. Các phương pháp của ông kết hợp mô hình hóa ngữ nghĩa của kiến thức chuyên gia với các phương pháp dựa trên dữ liệu được đào tạo từ dữ liệu của các sự cố bảo mật máy tính[2].

Điểm chính:

- **Mô hình hóa ngữ nghĩa:** Phương pháp này giúp các người phản ứng sự cố xác định những gì có khả năng đã xảy ra trước và sau một hành vi được quan sát, cung cấp những thông tin chi tiết có thể hành động cho việc trung hòa mối đe dọa.
- **Công cụ và phương pháp:** Các công cụ mã nguồn mở được sử dụng để trả lời các câu hỏi như “Điều gì có khả năng đã xảy ra trước khi quan sát này?” và “Các bước tiếp theo của kẻ thù có khả năng là gì dựa trên quan sát này?”[2].

3. Tối ưu hóa MITRE ATT&CK với Mô phỏng Cuộc tấn công và Rò rỉ (BAS)

Các giải pháp Mô phỏng Cuộc tấn công và Rò rỉ (BAS), chẳng hạn như Picus Security Control Validation (SCV), mô phỏng các mối đe dọa mạng thực tế để đánh giá hiệu quả của các biện pháp bảo mật. Cách tiếp cận này giúp giảm công sức thủ công và cải thiện hiệu quả của các biện pháp bảo mật thông qua tự động hóa các tác vụ lặp đi lặp lại[5].

Điểm chính:

- **Trường hợp sử dụng BAS:** Các đội đỏ nội bộ sử dụng BAS để tự động hóa các tác vụ cấp thấp, tập trung vào việc xác định các lỗi tấn công quan trọng và phát triển các kịch bản mối đe dọa tình vi.
- **Kịch bản tấn công tùy chỉnh:** Các đội đỏ có thể thiết kế các kịch bản tấn công tùy chỉnh thông qua giao diện kéo và thả đơn giản, tải lên các

payload của riêng họ để thử nghiệm các kỹ thuật cụ thể như tấn công vào các điểm cuối Windows[5].

4. Nghiên cứu tình huống: Nhóm mối đe dọa SALT TYPHOON

Một nhóm mối đe dọa có tên là SALT TYPHOON, gần đây đã được ghi nhận tấn công vào cơ sở hạ tầng của Hoa Kỳ, thể hiện sự áp dụng thực tiễn của các kỹ thuật MITRE ATT&CK trong các cuộc tấn công thực tế. Nghiên cứu này nêu bật tầm quan trọng của việc hiểu rõ cách các kỹ thuật ATT&CK xuất hiện trong các cuộc tấn công thực tế[5].

Điểm chính:

- **Thông tin mối đe dọa:** Nhóm mối đe dọa này sử dụng nhiều kỹ thuật MITRE ATT&CK khác nhau, chẳng hạn như **credential dumping** và **lateral movement**, để đạt được mục tiêu của họ.
- **Chiến lược phát hiện:** Bằng cách lập bản đồ các kỹ thuật này vào các cuộc tấn công thực tế, các đội bảo mật có thể phát triển các chiến lược phát hiện hiệu quả và cải thiện tư thế bảo mật tổng thể của họ[5].

Kết luận

Các tình huống sử dụng và nghiên cứu tình huống MITRE ATT&CK trong thực tế cho thấy ứng dụng thực tiễn của nó trong các tình huống trung tâm an ninh mạng (SOC) khác nhau. Bằng cách tận dụng các công cụ như ATT&CK Navigator và Mô phỏng Cuộc tấn công và Rò rỉ (BAS), các tổ chức có thể nâng cao thông tin mối đe dọa, cải thiện phản ứng sự cố và phát triển các chiến lược giám sát bảo mật mạnh mẽ. Những ví dụ này phản ánh bản chất đang phát triển của các mối đe dọa mạng và tầm quan trọng của việc liên tục thích ứng và cải tiến các biện pháp bảo mật.

Tài liệu tham khảo:

- [1] MITRE ATT&CK Framework: Breaking Down Attack Techniques
- [2] Automated ATT&CK Technique Chaining
- [5] Operationalizing MITRE ATT&CK with Breach and Attack Simulation

10. Đào Tạo và Phát Triển Kỹ Năng cho Các Nhà Phân Tích SOC về MITRE ATT&CK

Giới thiệu

Việc đào tạo và phát triển kỹ năng cho các nhà phân tích SOC về khung MITRE ATT&CK là rất quan trọng để nâng cao khả năng phát hiện và phản ứng với các mối đe dọa mạng tinh vi. Phần này sẽ tập trung vào những phát triển mới

nhất và các phương pháp tốt nhất trong việc đào tạo các nhà phân tích SOC để sử dụng hiệu quả khung MITRE ATT&CK.

Mục Tiêu Đào Tạo Chìa Khóa

1. **Hiểu Biết Về Khung:** Đảm bảo các nhà phân tích SOC có hiểu biết sâu sắc về cấu trúc của khung MITRE ATT&CK, bao gồm các chiến thuật, kỹ thuật và quy trình (TTPs) [5].
2. **Tích Hợp Thông Tin Đe Dọa:** Dạy cho các nhà phân tích cách tích hợp thông tin đe dọa với khung MITRE ATT&CK để nâng cao khả năng phát hiện [5].
3. **Bài Tập Thực Hành:** Cung cấp đào tạo thực hành thông qua các bài tập đội tím (purple team) mô phỏng các cuộc tấn công APT, malware không file và ransomware [1].
4. **Nghiên Cứu Trường Hợp và Tình Huống Sử Dụng:** Sử dụng các nghiên cứu trường hợp thực tế và tình huống sử dụng để minh họa ứng dụng thực tiễn của khung MITRE ATT&CK trong nhiều kịch bản khác nhau [5].

Phương Pháp Đào Tạo

1. **Hội Thảo và Hội Nghị:** Tham gia các hội thảo và hội nghị tập trung vào khung MITRE ATT&CK, chẳng hạn như Hội Thảo Cộng Đồng ATT&CK Khu Vực Châu Á – Thái Bình Dương, để nhận thông tin từ các chuyên gia trong ngành và kết nối với đồng nghiệp [5].
2. **Khóa Học và Chứng Chỉ Trực Tuyến:** Sử dụng các khóa học và chứng chỉ trực tuyến, chẳng hạn như khóa học OffSec Foundational Security Operations and Defensive Analysis (SOC-200), cung cấp đào tạo toàn diện về phát hiện đe dọa, phân tích nhật ký và hoạt động SIEM [3].
3. **Đào Tạo Dựa Trên Mô Phỏng:** Tham gia đào tạo dựa trên mô phỏng mô phỏng các kịch bản tấn công thực tế, cho phép các nhà phân tích thực hành kỹ năng của họ trong một môi trường kiểm soát [1].

Công Cụ và Công Nghệ

1. **Tích Hợp SIEM:** Sử dụng các công cụ Quản Lý Thông Tin và Sự Kiện Bảo Mật (SIEM) như các giải pháp SIEM dựa trên ELK để xác định và đánh giá các cuộc tấn công, đồng thời cấu hình chúng để theo dõi các cuộc tấn công đang diễn ra trên mạng [3].
2. **Công Cụ Tự Động Hóa:** Tận dụng các công cụ tự động hóa để tối ưu hóa quy trình phân tích, chẳng hạn như những công cụ được cung cấp bởi SentinelOne, có thể tự động hóa việc phát hiện và phản ứng với đe dọa [2].

Thực Hành Tốt Nhất

1. **Học Tập Liên Tục:** Khuyến khích việc học tập liên tục bằng cách cung cấp quyền truy cập vào 90 ngày tài liệu học trực tuyến và phòng lab, như được cung cấp bởi khóa học OffSec SOC-200 [3].
2. **Tham Gia Cộng Đồng:** Khuyến khích tạo ra một cộng đồng trực tuyến sôi nổi, nơi sinh viên và chuyên gia có thể chia sẻ kiến thức và thực hành tốt nhất, nâng cao trải nghiệm học tập [3].

Lệnh CLI và Tập Cấu Hình

Mặc dù các lệnh CLI và tập cấu hình cụ thể có thể thay đổi tùy thuộc vào các công cụ và công nghệ được sử dụng, dưới đây là một số ví dụ tổng quát:

- **Cấu Hình SIEM Dựa Trên ELK:**

```
# Ví dụ cấu hình cho SIEM dựa trên ELK
filebeat.inputs:
  - type: log
    enabled: true
    paths:
      - /var/log/*.log
output.elasticsearch:
  hosts: ["localhost:9200"]
  index: "logstash-2023.10.01"
```

- **Script Tự Động Hóa của SentinelOne:**

```
# Script ví dụ để tự động hóa phát hiện đe dọa với SentinelOne
import os
import json

# Tải tập cấu hình
with open('config.json', 'r') as f:
    config = json.load(f)

# Thiết lập kết nối API
api_key = config['api_key']
endpoint = config['endpoint']

# Định nghĩa quy tắc phát hiện
detection_rules = [
    {
        'name': 'Hành Vi Mạng Đáng Ngờ',
        'query': 'SELECT * FROM events WHERE type = "network" AND severity > 5'
    }
]
```

```
# Chạy quy tắc phát hiện
for rule in detection_rules:
    response = requests.post(endpoint + '/detections', headers={'Authorization': f'Bearer {token}'})
    if response.status_code == 200:
        print(f'Quy tắc phát hiện {rule["name"]} đã được thực thi thành công.')
    else:
        print(f'Lỗi khi thực thi quy tắc phát hiện {rule["name"]}: {response.text}')
```

Kết Luận

Việc đào tạo và phát triển kỹ năng cho các nhà phân tích SOC về khung MITRE ATT&CK là rất cần thiết để nâng cao khả năng phát hiện và phản ứng với các mối đe dọa mạng tinh vi. Bằng cách tập trung vào các bài tập thực hành, nghiên cứu trường hợp và học tập liên tục, các nhà phân tích SOC có thể tích hợp hiệu quả khung MITRE ATT&CK vào các hoạt động hàng ngày của họ, dẫn đến việc cải thiện khả năng phát hiện và phản ứng với đe dọa.

Tài Liệu Tham Khảo

- [1] MalTrak. In-Depth Investigation & Threat Hunting. 2025-03-20.
- [2] SentinelOne. SOC. 2025-03-19.
- [3] OffSec. OffSec Foundational Security Operations and Defensive Analysis (SOC-200). 2025-03-07.
- [5] MITRE. Asia-Pacific ATT&CK Community Workshop. 2025-03-12.

11. Công cụ và Công nghệ Hỗ Trợ Tích Hợp MITRE ATT&CK

Giới thiệu

Phần này tập trung vào các **công cụ** và **công nghệ** hỗ trợ tích hợp khung MITRE ATT&CK vào một Trung tâm Hoạt động Bảo mật (SOC). Nó làm nổi bật những phát triển và công cụ mới nhất nhằm tăng cường hiệu quả của việc sử dụng MITRE ATT&CK trong các quy trình SOC.

Công Cụ và Công Nghệ chính

1. Validato

- **Mô tả:** Validato cung cấp nền tảng kiểm tra dựa trên mối đe dọa, mô phỏng việc khai thác các kỹ thuật MITRE ATT&CK. Nó xác định các cấu hình không chính xác trong các môi trường Microsoft Windows, Linux và Mac, cung cấp thông tin khắc phục có hướng để giải quyết các lỗ hổng bảo mật[1][5].
- **Lệnh CLI/Tập cấu hình:** Mặc dù không có các lệnh CLI cụ thể, nền tảng của Validato có thể được tích hợp vào các công cụ SOC hiện có thông qua APIs và giao diện lập trình kịch bản.

2. SentinelOne

- **Mô tả:** SentinelOne cung cấp một tác nhân EDR thống nhất và phát hiện cũng như phản ứng mỗi đe dọa danh tính (ITDR) tích hợp với khung MITRE ATT&CK. Nó cung cấp khả năng bảo vệ danh tính mạnh mẽ trên endpoint và cái nhìn sâu sắc hơn về các hoạt động mỗi đe dọa[2].
- **Lệnh CLI/Tập cấu hình:** Cấu hình của SentinelOne liên quan đến việc thiết lập Nền tảng Singularity, bao gồm việc quản lý tác nhân EDR và cấu hình các nguồn cấp dữ liệu tình báo mỗi đe dọa. Ví dụ, việc thiết lập dịch vụ Singularity MDR bao gồm cấu hình công nghệ endpoint và khối lượng công việc đám mây để tích hợp với các kỹ thuật MITRE ATT&CK.

3. Senseon

- **Mô tả:** Senseon tích hợp khung MITRE ATT&CK vào nền tảng phát hiện mỗi đe dọa tự động, điều tra và phản ứng của nó. Nó sử dụng phân tích máy học và hình tam giác AI để hiểu và phân biệt giữa hoạt động độc hại và không độc hại[3].
- **Lệnh CLI/Tập cấu hình:** Nền tảng của Senseon liên quan đến việc thiết lập nhiều nguồn dữ liệu, kết hợp các phương pháp máy học và cấu hình hình tam giác AI. Chế độ điều tra cho thấy các trường hợp ưu tiên được tạo ra bởi hệ thống, cần được các nhà phân tích điều tra thêm.

4. Các Công Cụ Đáng Chú Ý Khác

- **Nền tảng Xác Thực Bảo Mật Tự Động:** Các nền tảng khác như đã đề cập trong [5] cung cấp xác thực các biện pháp bảo mật liên tục thông qua các mô phỏng tự động. Những công cụ này giúp các tổ chức đánh giá các biện pháp bảo mật của họ so với khung MITRE ATT&CK, đảm bảo bao quát toàn diện chống lại các mối đe dọa tiềm ẩn.

Triển Khai Thực Tế

1. Tích Hợp Công Cụ với Hạ Tầng Hiện Có

- Các công cụ như Validato và Senseon có thể được tích hợp vào các công cụ SOC hiện có thông qua APIs và giao diện lập trình kịch bản. Việc tích hợp này là rất quan trọng để tự động hóa quy trình xác thực bảo mật một cách liền mạch[1][3].

2. Cấu Hình Nguồn Cấp Dữ Liệu Tình Báo Mỗi Đe Dọa

- Các công cụ như SentinelOne yêu cầu cấu hình các nguồn cấp dữ liệu tình báo mỗi đe dọa để phù hợp với khung MITRE ATT&CK. Điều này đảm bảo rằng hệ thống luôn được cập nhật với thông tin tình báo và kỹ thuật mỗi đe dọa mới nhất[2].

3. Sử Dụng Machine Learning và AI

- Các công cụ như Senseon tận dụng máy học và AI để tự động hóa việc phát hiện, phân loại, điều tra và phản ứng. Điều này nâng cao tốc độ và độ chính xác trong việc phát hiện và phản ứng với các mối đe dọa[3].

4. Tăng Cường Tính Hiện Thị và Ngữ Cảnh

- Các công cụ như Senseon cung cấp tính hiện thị vượt trội bằng cách thu thập dữ liệu từ nhiều điểm khác nhau trong tổ chức. Ngữ cảnh tăng cường này giúp giảm tiếng ồn và cải thiện độ chính xác của các cảnh báo[3].

Kết Luận

Việc tích hợp MITRE ATT&CK với các công cụ và công nghệ khác nhau là rất quan trọng để nâng cao hiệu quả của một SOC. Bằng cách tận dụng các công cụ như Validato, SentinelOne và Senseon, các tổ chức có thể tự động hóa quy trình xác thực bảo mật, cải thiện khả năng phát hiện mối đe dọa và duy trì một hàng rào bảo vệ vững chắc chống lại các mối đe dọa đang phát triển. Triển khai thực tế liên quan đến việc tích hợp các công cụ này với hạ tầng hiện có, cấu hình các nguồn cấp dữ liệu tình báo mối đe dọa, và sử dụng máy học cùng AI để nâng cao tính hiện thị và ngữ cảnh.

12. Thách Thức và Hạn Chế Khi Áp Dụng MITRE ATT&CK Trong SOC

1. Đào Tạo Toàn Diện và Kiến Thức Chuyên Biệt

Việc áp dụng khung MITRE ATT&CK một cách hiệu quả đòi hỏi **đào tạo toàn diện** và kiến thức chuyên biệt. Độ phức tạp của khung này, với 14 chiến thuật, 203 kỹ thuật và 453 tiểu kỹ thuật, yêu cầu sự hiểu biết sâu sắc về hành vi và chiến thuật của kẻ thù[1][3].

2. Tốn Tài Nguyên

Việc triển khai khung MITRE ATT&CK tốn nhiều tài nguyên. Nó cần rất nhiều thời gian và nỗ lực để duy trì kiến thức cập nhật về các chiến thuật và kỹ thuật của kẻ thù, cũng như liên tục đánh giá và điều chỉnh các biện pháp bảo mật[1][3].

3. Thách Thức Quản Lý Dữ Liệu

Khối lượng dữ liệu lớn của khung này đặt ra những khó khăn đặc biệt đối với các tổ chức cố gắng khớp dữ liệu hiện tại một cách đầy đủ, đặc biệt là khi liên quan đến các chiến thuật truy cập ban đầu. Điều này có thể dẫn đến những thách thức trong việc xác định và liên kết các điểm dữ liệu liên quan[1][3].

4. Sự Tinh Vi Của Kẻ Thù

Sự tinh vi ngày càng tăng của các mối đe dọa hiện đại, được nhấn mạnh bởi báo cáo Red Report 2025 từ Picus Labs, làm nổi bật độ phức tạp ngày càng gia tăng của các mối đe dọa. Kẻ thù sẽ tiếp tục phát triển các chiến thuật của

mình, cho nên việc thường xuyên xem xét và xác nhận độ bao phủ hiện có là điều cần thiết[3].

5. Giảm Nỗ Lực Thủ Công

Một trong những thách thức lớn là giảm nỗ lực thủ công cần thiết để hiện thực hóa khung này. Đây là lúc các công cụ như **Breach and Attack Simulation (BAS)** phát huy tác dụng, tự động hóa các tác vụ lặp đi lặp lại và cho phép các đội đổ tập trung vào các mô phỏng tấn công phức tạp và sáng tạo hơn[3].

6. Tích Hợp Với Các Hệ Thống Hiện Có

Việc tích hợp khung MITRE ATT&CK vào các hệ thống bảo mật hiện có có thể gặp khó khăn. Các SIEM truyền thống thường gặp khó khăn với các phân tích phức tạp và khối lượng dữ liệu lớn, đòi hỏi các giải pháp tùy chỉnh như những gì đã được phát triển tại Phòng Thí Nghiệm Vật Lý Ứng Dụng Johns Hopkins[2].

7. Gian Lận Trong Bao Phủ

Mặc dù khung này rất toàn diện, nhưng luôn có những khoảng trống trong bao phủ. Các đội bảo mật cần liên tục giám sát và tinh chỉnh chiến lược phát hiện của mình để phù hợp với hành vi tấn công trong thế giới thực. Các công cụ như **Datadog Cloud SIEM MITRE ATT&CK Map** giúp xác định các khoảng trống này và cải thiện độ bao phủ phát hiện[5].

8. Hợp Tác và Đào Tạo

Sự hợp tác với các chuyên gia an ninh mạng để giáo dục và tư vấn có thể giảm bớt những trở ngại này. Việc thường xuyên làm mới chiến lược phản ứng sự cố với các kỹ thuật gần đây từ khung MITRE ATT&CK đảm bảo rằng các tổ chức được trang bị tốt hơn để dự đoán và chống lại các mối đe dọa an ninh mới[1][3].

Các Cân Nhắc Thực Tiễn

Lệnh CLI và Tập Tin Cấu Hình Mặc dù không có lệnh CLI cụ thể và tập tin cấu hình được đề cập trong bối cảnh thách thức, việc hiểu cách tích hợp các công cụ như **BAS** hoặc **Datadog Cloud SIEM** vào các quy trình SOC của bạn là rất quan trọng. Ví dụ, việc sử dụng các công cụ như **Picus Security Control Validation (SCV)** liên quan đến việc mô phỏng các mối đe dọa mạng trong thực tế để đánh giá hiệu quả của các biện pháp bảo mật[3].

Đoạn Mã Không có đoạn mã cụ thể nào cần thiết cho mục này, vì nó tập trung vào các thách thức khái niệm thay vì chi tiết triển khai kỹ thuật. Tuy nhiên, việc hiểu cách sử dụng các công cụ như **trình biên tập quy tắc tùy chỉnh của Datadog** để tạo ra các quy tắc phát hiện với các thẻ chiến thuật và kỹ thuật đã được điền sẵn là cần thiết cho việc triển khai thực tế[5].

Tài Liệu Tham Khảo

- [1] MITRE ATT&CK Framework: Breaking Down Attack Techniques
- [2] Operationalizing MITRE ATT&CK with Breach and Attack Simulation
- [5] Identify Gaps to Strengthen Detection Coverage With the Datadog Cloud SIEM MITRE ATT&CK Map

13. Hướng đi tương lai và cải tiến cho MITRE ATT&CK trong lĩnh vực an ninh mạng

1. Tích hợp với AI và Machine Learning

- **Phát hiện nâng cao:** Việc tích hợp AI và machine learning với khung MITRE ATT&CK có thể cải thiện đáng kể khả năng phát hiện mối đe dọa. Ví dụ, phân tích dựa trên AI có thể giúp xác định các mẫu và bất thường mà có thể không rõ ràng đối với các nhà phân tích con người[3][5].
- **Phân tích dự đoán:** Bằng cách tận dụng phân tích dự đoán, các tổ chức có thể dự đoán và chuẩn bị cho các cuộc tấn công tiềm tàng. Điều này bao gồm việc sử dụng mô hình machine learning để dự đoán tác động hoạt động của một mô hình AI, bao gồm tần suất các cuộc tấn công đã thực hiện và thành công[1][5].

2. Tự động hóa và tích hợp SOAR

- **Orchestration, Automation, and Response (SOAR):** Việc tích hợp các nền tảng SOAR với khung MITRE ATT&CK có thể tối ưu hóa quy trình phản ứng với sự cố. SOAR nâng cao phân tích mối đe dọa theo thời gian thực và phản ứng với sự cố sau phát hiện với các dẫn xuất điều tra và dữ liệu phong phú hơn[3][5].
- **Cảnh báo tự động:** Các hệ thống cảnh báo tự động có thể giảm thiểu tiếng ồn trong các hoạt động an ninh bằng cách tập trung vào các mối đe dọa ưu tiên cao. Điều này đặc biệt hữu ích trong các môi trường mà phân tích thủ công là tốn thời gian và tài nguyên[2][5].

3. Blockchain và Học tập liên phân vùng (Federated Learning)

- **Tăng cường độ tin cậy và khả năng mở rộng:** Chia sẻ thông tin tình báo dựa trên blockchain và học tập liên phân vùng có thể cải thiện độ chính xác và hiệu quả của các đánh giá tình báo mối đe dọa. Những công nghệ này có thể giúp giảm thiểu một số rủi ro an ninh liên quan đến phát hiện mối đe dọa dựa trên AI, chẳng hạn như các dương tính giả và các cuộc tấn công đối kháng[3][5].
- **Tính toàn vẹn dữ liệu:** Blockchain đảm bảo tính toàn vẹn dữ liệu bằng cách cung cấp một bản ghi minh bạch và không thể làm giả của tất cả các giao dịch. Điều này rất quan trọng để duy trì tính đáng tin cậy của dữ liệu tình báo mối đe dọa[3].

4. Giám sát liên tục và chia sẻ tình báo mối đe dọa

- **Hợp tác toàn cầu:** Các khung chia sẻ tình báo mối đe dọa như STIX và TAXII có thể hỗ trợ khung MITRE ATT&CK bằng cách thúc đẩy hợp tác toàn cầu và cải thiện khả năng phục hồi an ninh mạng. Những khung này tổ chức tình báo mối đe dọa thu thập từ nhiều nguồn khác nhau, nâng cao nhận thức tình huống và giảm thiểu rủi ro[3][5].
- **Phân tích mối đe dọa theo thời gian thực:** Giám sát liên tục và phân tích mối đe dọa theo thời gian thực là rất cần thiết cho các chiến lược phòng thủ chủ động. Điều này liên quan đến việc sử dụng phân tích nâng cao để phát hiện hành vi bất thường và dự đoán các mối đe dọa đang phát triển[3].

5. Phân tích nâng cao và phân tích hành vi

- **Mẫu hành vi:** Phân tích nâng cao và phân tích hành vi có thể phát hiện các chỉ số tinh vi của sự xâm nhập và các mẫu bất thường có thể chỉ ra các hoạt động độc hại. Quy trình này thường là lặp đi lặp lại và được điều hướng bởi giả thuyết, yêu cầu hiểu biết sâu sắc về các hệ thống của tổ chức và các bối cảnh mối đe dọa tiềm tàng[2][3].
- **Cải tiến Machine Learning:** Machine learning có thể nâng cao khả năng phát hiện hành vi bất thường và dự đoán các mối đe dọa đang phát triển. Bằng cách tận dụng các mô hình machine learning, các tổ chức có thể cải thiện hiệu quả của quy trình phát hiện và phản ứng với mối đe dọa[3][5].

Kết luận

Tương lai của khung MITRE ATT&CK trong lĩnh vực an ninh mạng gắn liền chặt chẽ với những tiến bộ trong AI, machine learning, tự động hóa và công nghệ đảm bảo tính toàn vẹn dữ liệu. Bằng cách tích hợp những công nghệ này, các tổ chức có thể cải thiện khả năng phát hiện mối đe dọa, tối ưu hóa quy trình phản ứng với sự cố và nâng cao khả năng phục hồi tổng thể của an ninh mạng. Sự phát triển liên tục của khung MITRE ATT&CK sẽ vẫn là điều cần thiết cho việc duy trì một chiến lược phòng thủ chủ động và thích ứng trước bối cảnh các mối đe dọa mạng ngày càng thay đổi.

Tài liệu tham khảo: - [1] A Framework for Evaluating Emerging Cyberattack Capabilities of AI - [3] THREAT INTELLIGENCE: ROLE IN MODERN CYBERSECURITY - [5] Early Disruptive Trends in Cybersecurity - Skyhawk Security

14. Kết luận và Những điểm chính

Tóm tắt những điểm chính

1. **Nâng cao nhận thức về mối đe dọa:** Khung MITRE ATT&CK nâng cao đáng kể nhận thức về mối đe dọa bằng cách cung cấp một bản đồ chi

tiết về các chiến thuật, kỹ thuật và thủ tục (TTPs) của kẻ tấn công. Sự hiểu biết chi tiết này cho phép các tổ chức dự đoán và đối phó với các mối đe dọa mạng tiềm ẩn một cách hiệu quả hơn[1][3].

2. **Cải thiện khả năng phản ứng sự cố:** Khung này tạo điều kiện cải thiện khả năng đáp ứng sự cố bằng cách cung cấp một lộ trình chi tiết để phát hiện và giảm thiểu các mối đe dọa mạng. Điều này bao gồm các phương pháp cụ thể để xác định các chỉ số của sự xâm phạm (IOCs) và các chiến lược để containment và remediation[1][3].
3. **Hợp tác và tiêu chuẩn hóa:** Khung MITRE ATT&CK thúc đẩy sự hợp tác giữa các đội đỏ (mô phỏng tấn công) và đội xanh (người bảo vệ) bằng cách cung cấp một thuật ngữ chung và cách tiếp cận có cấu trúc để hiểu hành vi của kẻ tấn công. Sự tiêu chuẩn hóa này cải thiện các nỗ lực chung và sự hiểu biết trong lĩnh vực an ninh mạng[1][3].
4. **Ứng dụng thực tế:** Những hiểu biết thực tiễn của khung về các ví dụ cụ thể liên quan đến hành vi của kẻ tấn công làm cho nó trở nên vô giá cho các trung tâm hoạt động an ninh (SOC). Điều này giúp hiểu cách các kỹ thuật biểu hiện trong các cuộc tấn công thực tế, từ đó cho phép triển khai các chiến lược phát hiện và phản ứng hiệu quả hơn[1][5].
5. **Tích hợp với công cụ và công nghệ:** Khung này có thể được tích hợp với nhiều công cụ và công nghệ khác nhau, chẳng hạn như Splunk, để nâng cao khả năng sẵn lòng mỗi đe dọa. Các công cụ như ThreatHunting for Splunk cung cấp các bảng điều khiển phù hợp với khung MITRE ATT&CK, hỗ trợ trong việc xác định các sự kiện đáng ngờ và giảm thiểu tiếng ồn trong các cảnh báo an ninh[5].
6. **Đào tạo và phát triển kỹ năng:** Đào tạo các nhà phân tích SOC về khung MITRE ATT&CK là rất quan trọng cho việc phát triển kỹ năng của họ. Điều này bao gồm việc hiểu các chiến thuật, kỹ thuật và quy trình được nêu trong khung, giúp các nhà phân tích chủ động bảo vệ trước các mối đe dọa đang phát triển[3].
7. **Thách thức và giới hạn:** Mặc dù có nhiều lợi ích, việc áp dụng khung MITRE ATT&CK trong các SOC gặp phải nhiều thách thức. Các thách thức này bao gồm việc cần liên tục cập nhật để theo kịp các mối đe dọa đang tiến hóa và độ phức tạp trong việc tích hợp khung với các công cụ và quy trình an ninh hiện có[1][3].

Hướng đi và nâng cao trong tương lai

1. **Tự động hóa và tích hợp AI:** Các cải tiến trong tương lai của khung MITRE ATT&CK có thể bao gồm nhiều hơn nữa khả năng tự động hóa và phát hiện dựa trên AI. Điều này sẽ hỗ trợ tối ưu hóa quy trình phân tích, giảm thiểu các báo động giả và cải thiện hiệu quả tổng thể trong phát hiện và phản ứng trước mối đe dọa[2][4].

2. **Hướng dẫn phát hiện nâng cao:** Việc cập nhật liên tục khung nên tập trung vào việc cung cấp hướng dẫn phát hiện chi tiết hơn và các tiểu kỹ thuật. Điều này giúp cải thiện khả năng xác định và giảm thiểu các mối đe dọa nâng cao có thể vượt qua các biện pháp an ninh truyền thống[1].
3. **Khuyến khích sự tham gia của cộng đồng:** Khuyến khích sự tham gia của cộng đồng và chia sẻ thông tin mới về mối đe dọa là điều thiết yếu cho sự thành công liên tục của khung. Điều này bao gồm việc tích hợp các thông tin từ nhiều nguồn khác nhau, bao gồm các báo cáo ngành và nghiên cứu học thuật, để giữ cho khung luôn phù hợp và hiệu quả[1][3].

Tài liệu tham khảo

- [1] MITRE Corporation. (2025, March 25). MITRE ATTACK Framework: Breaking Down Attack Techniques.
- [2] SentinelOne. (2025, March 19). SOC | SentinelOne.
- [3] Codelivly. (2025, March 07). Understanding SOC: Everything you need for a career as a SOC analyst.
- [4] FIRST Conference Program. (2025, March 23). Automated ATT&CK Technique Chaining.
- [5] Security Affairs. (2025, March 31). ATT&CKized Splunk - Threat Hunting with MITRE's ATT&CK using Splunk.